UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

Fecha: 15 de octubre del 2026

PLAN DE RESPUESTA ANTE INCIDENTES DE CIBERSEGURIDAD (CSIRT-INTERAFAS)

Mtro. Servando López Contreras

Informe realizado por:

181583 Angel Aaron Acuña Quezada

Contenido

Propósito, Alcance y Clasificación de Incidentes 3

2. Roles, Responsabilidades y Estructura del CSIRT 4

3. Preparación, Detección y Reporte 4

4. Análisis, Triage y Priorización 5

5. Estrategias de Contención 6

6. Erradicación y Remediación 7

7. Recuperación y Mecanismos de Rollback 8

8. Coordinación y Escalamiento Ejecutivo 9

9. Playbooks Operativos Derivados de INTERAFAS-LAB 9

PLAYBOOK 01 (PB-01): Respuesta ante Fuga de Datos por Control de Acceso Roto (IDOR / BOLA) y Secuestro de Sesión 9

PLAYBOOK 02 (PB-02): Respuesta ante Inyección SQL Ciega (Blind SQLi) y Exfiltración de Base de Datos 10

PLAYBOOK 03 (PB-03): Respuesta ante Inyección XSS Almacenado y Lectura Arbitraria de Archivos (Path Traversal) 11

PLAYBOOK 04 (PB-04): Respuesta ante Fraude en Pasarela de Pagos y Abuso de Lógica de Negocio 13

PLAYBOOK 05 (PB-05): Respuesta Crítica ante Intrusión en Red OT, Manipulación de Firmware RTU y Sabotaje de Presión 14

10. Post-Incidente, Métricas y Mejora Continua 16

Propósito, Alcance y Clasificación de Incidentes

1. **Propósito:** Establecer la estrategia, los procedimientos estandarizados y los *playbooks* operativos de **INTERAFAS** para preparar, detectar, analizar, contener, erradicar y recuperar la infraestructura tecnológica (IT) y operacional (OT) ante incidentes de ciberseguridad, siguiendo la metodología de los *Playbooks* de respuesta a incidentes y vulnerabilidades de **CISA**.
2. **Alcance:** Aplica obligatoriamente a todos los servidores web (/var/www/html), bases de datos (db:3306 / interafas), APIs, pasarelas de red (/operations/gateway.php), consolas SCADA/HMI (HMI-OPS-01), historiadores (HIST-01/BRS-01) y dispositivos de campo (RTU-GW-07 y los 18 PLCs) que operan el suministro de agua en Cerro de San Pablo, Saint Louis y Soledade.
3. **Concepto de Incidente de Ciberseguridad:** Cualquier evento real o inminente que comprometa sin autorización la confidencialidad, integridad o disponibilidad de un activo de información o de un proceso físico industrial de INTERAFAS, o que viole las políticas de su SGSI.

Criterios de Severidad, Prioridades y Condiciones de Activación:

Nivel de Severidad	Prioridad y SLA de Respuesta	Criterio Técnico / Operacional (Basado en INTERAFAS-LAB)	Condición de Activación
SEV-1: Crítico (F4 - Impacto OT)	**P1 (Inmediata: < 15 min)**	Intrusión en red OPS-NET-20 (10.40.20.0/24), alteración de firmware en RTU-GW-07 o cambios en setpoints de presión (10 bar / CATASTROPHIC STATE).	Cualquier alerta en /operations/, cambio a UNLOCKED o alarma de presión en HMI.
SEV-2: Alto (F3 - Brecha de BD / Control)	**P2 (Urgente: < 30 min)**	Explotación de Blind SQLi (validar-referencia.php), Path Traversal a /etc/, escalamiento de rol a procurement_admin o fraude en pago.php.	Detección de inyección en logs de Apache/MySQL o discrepancias en tablas financieras/padrón.
SEV-3: Medio (F2 - Exposición de Cuentas)	**P3 (Prioritaria: < 2 hrs)**	Consultas cruzadas IDOR (expediente.php), BOLA (service-history.php), Stored XSS (reportes.php) o Session Replay (PHPSESSID).	Múltiples peticiones secuenciales sobre parámetros id/account o alertas de sesión duplicada.
SEV-4: Bajo (F1 - Reconocimiento)	**P4 (Programada: < 8 hrs)**	Escaneos con gobuster, descarga de archivos .bak/.zip olvidados o errores 500 UnhandledMatchError en exportar.php.	Aumento inusual de códigos 403/404/500 en access.log de Apache.

2. Roles, Responsabilidades y Estructura del CSIRT

Rol en el Equipo de Respuesta	Área / Puesto Asignado	Funciones Específicas Durante el Incidente
Líder de Respuesta a Incidentes (IR Lead)	Titular de Ciberseguridad / Líder SGSI	Dirige la ejecución de los playbooks CISA, coordina el triage, autoriza el aislamiento de red y enlaza con Dirección General.
Responsables Técnicos TI / WebOps	Administradores de Servidores, BD y Desarrollo Web	Analizan logs de Apache/PHP, aplican parches de emergencia (PDO, realpath, htmlspecialchars), revocan sesiones y depuran /var/www/html.
Responsables Técnicos OT / Planta	Ingenieros de Control y Mantenimiento (OPS-NET-20)	Pasan los PLCs y bombas a operación manual segura en sitio, restauran el respaldo limpio en RTU-GW-07 desde BRS-01 y bloquean ventanas de mantenimiento.
Dirección General	Director(a) General de INTERAFAS	Autoriza decisiones de alto impacto (apagado temporal del portal ciudadano o desconexión total del puente operations-bridge).
Área Jurídica y Cumplimiento	Titular de Asuntos Jurídicos	Custodia legalmente la evidencia forense, documenta el incidente para denuncias penales y notifica al Órgano Garante (LGPDPPSO).
Comunicación Social	Director(a) de Comunicación Social	Ejecuta el Plan de Comunicación de Crisis (04) en sincronía con los hallazgos confirmados por el IR Lead.
Terceros y Autoridades	Proveedores de Soporte, CERT-MX y CONAGUA	Asistencia forense especializada, compartición de Indicadores de Compromiso (IoCs) y coordinación de emergencia hídrica metropolitana.

3. Preparación, Detección y Reporte

Alineado con la fase de *Preparation* y *Detection* de CISA:

- **Mecanismos previos de preparación:**
    1. Mantenimiento de copias de seguridad doradas (*Golden Images*) verificadas del firmware 3.4.3 (diagnostic: LOCKED, pressure_setpoint_bar: 4.2) en el servidor BRS-01 fuera de línea.
    2. Sincronización de relojes mediante NTP en el servidor Debian, base de datos db:3306, historiador HIST-01 y consola HMI-OPS-01 para garantizar correlación temporal en bitácoras.
    3. Reglas preconfiguradas en firewall para cortar instantáneamente el puente web-to-operations en caso de contingencia.
- **Fuentes de detección:**

  - *Capa Web y API:* Bitácoras access.log y error.log de Apache/2.4.68 (detección de sqlmap, saltos ../../, errores 500 en exportar.php y cabeceras X-Forwarded-For).
  - *Capa de Base de Datos:* Monitoreo de consultas booleanas masivas sobre validar-referencia.php y lecturas a tablas sensibles (firmware_support_users).
  - *Capa Industrial OT:* Alertas en el HMI (Metropolitan Water Operations), cambios de estado a UNLOCKED en RTU-GW-07, y desviaciones de presión fuera del rango 4.1–4.5 bar en HIST-01.

- **Recepción de alertas, registro y canales de reporte:** Cualquier alerta automática o reporte humano se registra en el Sistema de Tickets de Incidentes del CSIRT asignándole un folio único, sello de tiempo y severidad inicial. Canales habilitados 24/7: correo csirt@interafas.gob.mx, extensión de emergencia 2700 y canal de radio directo entre Planta Norte y TI en caso de caída de la red IP.

4. Análisis, Triage y Priorización

Siguiendo el diagrama de flujo de *Triage and Analysis* de CISA:

1. **Validación y descarte de falsos positivos:** El analista en turno cruza la alerta entre al menos dos fuentes (por ejemplo, correlacionar una petición POST /operations/updates/install.php en el log web con el evento RTU-GW-07 diagnostic changed to SERVICE a las 11:35 en el registro de mantenimiento OT).
2. **Determinación de alcance (*Scoping*):** Identificar qué cuentas ciudadanas, qué tablas de interafas y qué eslabones de la cadena de activos OT (RTU-GW-07 → PLC-SL-01 → V-SL-201 → ZONE-SL-A) fueron consultados o modificados por la sesión o IP del atacante.
3. **Clasificación y Priorización:** Se asigna la prioridad (P1 a P4). **Regla crítica:** Si un incidente afecta simultáneamente TI y OT (como ocurrió en INTERAFAS-LAB), **la estabilización física de la red de agua (OT) tiene prioridad absoluta (P1)** sobre la disponibilidad del portal web.

4. **Preservación de evidencia forense:** Antes de reiniciar contenedores o borrar archivos, se genera una copia bit a bit (*snapshot*) de /var/log/apache2/, el volcado de transacciones de MySQL, el estado de memoria de las sesiones PHP (/var/lib/php/sessions), la tabla de eventos del historiador HIST-01 y el paquete JSON malicioso inyectado en la RTU, calculando su hash SHA-256 para mantener la cadena de custodia legal.
5. **Escalamiento:** Si el triage confirma severidad SEV-1 o SEV-2, el IR Lead escala en menos de 15 minutos a la Dirección de Operaciones OT, Dirección General y Comité de Comunicación de Crisis.

5. Estrategias de Contención

Se dividen en dos fases cuidando en todo momento la continuidad del suministro de agua y la preservación de evidencia:

Contención Inmediata (Corto Plazo):

1. *Desacoplamiento IT/OT (Frontera web-to-operations):* Bloquear de inmediato en el firewall interno todo tráfico entre el servidor web (localhost:8080) y la subred operacional 10.40.20.0/24, deshabilitando el script /operations/gateway.php para cortar el control remoto del atacante sin apagar las bombas de agua.
2. *Paso a control local en Planta:* Ordenar a los operadores de la Planta Metropolitana Norte y de las estaciones de Cerro de San Pablo, Saint Louis y Soledade conmutar los 18 PLCs y las 46 unidades de bombeo a modo **Local / Manual**, regulando físicamente las válvulas a 4.2 bar.
3. *Revocación de sesiones y cuentas comprometidas:* Vaciar la tabla/directorio de sesiones activas de PHP (invalidando todos los PHPSESSID y cookies portal_role) y deshabilitar temporalmente la cuenta de soporte Básico (Soporte343).

Contención Prolongada (Mediano Plazo):

1. Colocar el Portal Ciudadano, /pago.php, /reportes.php y /validar-referencia.php en modo de mantenimiento estático mientras se corrige

el código, manteniendo activa únicamente la página informativa de contingencia.

2. Aplicar reglas temporales en un WAF (*Web Application Firewall*) para filtrar payloads SQLi, etiquetas <script>, secuencias ../ y cabeceras X-Forwarded-For provenientes del exterior.

6. Erradicación y Remediación

Conforme a la fase de *Eradication* de CISA, no se procede a la recuperación sin antes eliminar la causa raíz y cualquier persistencia:

1. **Eliminación de artefactos y persistencia:**
    - Borrar de la base de datos los registros inyectados con payloads XSS en la tabla reportes_ciudadanos (como el folio REP-20261011-D9A3AB).
    - Eliminar del directorio público /var/www/html los archivos residuales transparencia.php.bak y el directorio /assets/docs/public/revision/ con su paquete .zip y .env.
    - Retirar la interfaz de desfiguración /system.php dejada por el *Colectivo Umbral* y verificar que no existan *webshells* ni tareas programadas (cron) no autorizadas en el servidor Debian.
2. **Corrección de vulnerabilidades de código y configuración (Remediación de las 20 fallas):**
    - Reemplazar consultas concatenadas por **PDO Prepared Statements** en /validar-referencia.php.
    - Implementar validación estricta de sesión y pertenencia ($_SESSION['user_id'] y $_SESSION['role']) en expediente.php, service-history.php y gestion-proveedores.php, eliminando la cookie portal_role.
    - Asegurar pago.php (lectura de saldo desde BD) y validar-vinculo-contractual.php (INNER JOIN).

- Aplicar basename()/realpath() en descargar-documento.php, htmlspecialchars() en seguimiento-reporte.php, session_regenerate_id(true) en login.php y apagar display_errors / Options +Indexes.

7. Recuperación y Mecanismos de Rollback

Secuencia de restauración segura (Orden de prioridad):

- **Fase A (Infraestructura OT):** Restaurar la configuración de RTU-GW-07 desde el respaldo limpio validado en BRS-01 (RTU-GW-07-backup.json con "pressure_setpoint_bar": 4.2 y "diagnostic": "LOCKED"). Reconectar gradualmente los 18 PLCs y las 12 estaciones al control supervisado del HMI (HMI-OPS-01) verificando que las alarmas bajen a 0 y la disponibilidad vuelva al 99.82%.
- **Fase B (Base de Datos y Servicios Internos):** Restaurar la integridad de las tablas facturas, pagos_simulados y proveedores revirtiendo los pagos de $1.00 (referencia PAY-261012-AD7FDE) y los cambios de estado en el padrón.
- **Fase C (Portal Ciudadano y APIs):** Poner en línea el portal web endurecido habilitando primero los módulos informativos y posteriormente el acceso ciudadano y pasarela de pagos.

Criterios objetivos para volver a operación normal:

- Presión hidráulica estable entre 4.1 y 4.5 bar durante 6 horas continuas sin alertas en HIST-01.
- 0 vulnerabilidades altas o críticas abiertas en el checklist de validación (CHK-01 al CHK-20).
- Tráfico entre la web pública y la red 10.40.20.0/24 completamente bloqueado y verificado.

Monitoreo reforzado post-recuperación: Durante los **15 días** posteriores al retorno a producción, se mantiene vigilancia intensiva sobre /var/log/apache2/access.log, intentos de login fallidos, consultas a /api/ y telemetría de RTU-GW-07 cada 5 minutos.

Mecanismos de Rollback (Marcha atrás de emergencia): Si durante la reconexión del HMI o del portal se detecta cualquier persistencia no erradicada, caída de presión o comportamiento anómalo en los PLCs, se ejecuta el *Rollback Inmediato*: desconexión física del puerto de red de RTU-GW-07, retorno instantáneo de las estaciones de bombeo a operación manual en sitio y reversión del contenedor web a mantenimiento estático en menos de **3 minutos**.

8. Coordinación y Escalamiento Ejecutivo

Nivel / Evento	Tiempo Máximo	A Quién se Escala	Canal y Propósito de Coordinación
Detección Técnica (Triage P1/P2)	**15 minutos**	Líder CSIRT + Director de Operaciones OT + CISO	Canal de emergencia TI-OT: coordinar aislamiento inmediato del gateway /operations/gateway.php y paso a control manual en Planta Norte.
Escalamiento Ejecutivo	**30 minutos**	Dirección General de INTERAFAS	Llamada directa: autorizar paro temporal de servicios web ciudadanos y activar formalmente los comités de respuesta y crisis.
Coordinación con Comunicación de Crisis	**45 minutos**	Comité de Comunicación de Crisis (Plan 04)	Entregar datos técnicos validados para emitir el Holding Statement sin comprometer la investigación forense ni filtrar datos de red OT.
Notificación a Terceros (Proveedores)	**4 horas**	Dirección de Contrataciones → 219 Proveedores	Aviso preventivo de suspensión temporal del validador contractual y verificación de integridad del padrón.
Notificación a Autoridades Regulatorias	**24 a 72 horas**	Jurídico → CONAGUA, Órgano Garante (LGPDPPSO) y CERT-MX	Reporte oficial de incidente en infraestructura hídrica y notificación legal por exposición de datos personales en expedientes.

9. Playbooks Operativos Derivados de INTERAFAS-LAB

PLAYBOOK 01 (PB-01): Respuesta ante Fuga de Datos por Control de Acceso Roto (IDOR / BOLA) y Secuestro de Sesión

- **Escenario de INTERAFAS-LAB atendido:** VULN-03 (expediente.php?id=2), VULN-06 (cookie portal_role=procurement_admin), VULN-10 (Session Replay de PHPSESSID), VULN-11 y VULN-12 (/api/service-history.php?account=40010002).
- **Disparador (*Trigger*):** Detección en logs de múltiples peticiones secuenciales sobre ?id= o ?account= desde un mismo PHPSESSID, aparición de portal_role=procurement_admin en una cuenta ciudadana (ciudadano01), o reutilización de un ID de sesión desde distintas direcciones IP/User-Agents.
- **Responsables:** Administradores de Desarrollo Web (R), Líder CSIRT (A), Jurídico/Privacidad (C).

- **Evidencia a Recolectar:** Registros de /var/log/apache2/access.log con las URLs enumeradas, archivos de sesión de PHP vinculados al PHPSESSID infractor, lista exacta de IDs de expedientes (EXP-2026-00422 - Carlos Rivera) y cuentas (40010002) consultadas sin autorización.
- **Acciones de Contención:**
    1. Destruir de inmediato todas las sesiones activas en el servidor (rm /var/lib/php/sessions/sess_*) forzando reautenticación global.
    2. Bloquear temporalmente la cuenta origen (ciudadano01) y deshabilitar el acceso externo a /gestion-proveedores.php y /api/service-history.php.
- **Erradicación y Recuperación:**
    1. Desplegar parche en expediente.php y service-history.php vinculando la consulta a $_SESSION['user_id'].
    2. Eliminar la lectura de la cookie portal_role validando el rol exclusivamente en servidor, e incorporar session_regenerate_id(true) en login.php.
    3. Revertir cualquier cambio de estado en el padrón de proveedores realizado durante la intrusión.
- **Criterio de Cierre:** Verificación en Burp Repeater de que cambiar ?id=2, ?account=40010002 o editar cookies devuelve 403 Forbidden, y notificación enviada a los titulares cuyos datos personales fueron visualizados.

PLAYBOOK 02 (PB-02): Respuesta ante Inyección SQL Ciega (Blind SQLi) y Exfiltración de Base de Datos

- **Escenario de INTERAFAS-LAB atendido:** VULN-05 (fuga de db:3306 / schema interafas en exportar.php) y VULN-07 (Boolean-based Blind SQLi con sqlmap sobre /validar-referencia.php?ref=).
- **Disparador (*Trigger*):** Ráfaga de peticiones HTTP (> 50 req/min) hacia /validar-referencia.php o endpoints con parámetros de consulta conteniendo operadores lógicos (AND, OR, SUBSTRING, ASCII), User-Agent de sqlmap, o alertas de errores 500 en /exportar.php.

- **Responsables:** Administrador de Base de Datos y Backend (R), Líder CSIRT (A), Ingeniería OT (I - por exposición de tabla firmware_support_users).
- **Evidencia a Recolectar:** Volcado de access.log con los payloads inyectados (ref=LP-INT-029-2026' AND 5836=5836...), registro general de consultas de MySQL/MariaDB para identificar qué tablas de las 32 fueron leídas (portal_validation_meta, usuarios, firmware_support_users).
- **Acciones de Contención:**
    1. Bloquear la IP origen en el firewall/WAF y deshabilitar temporalmente el script /validar-referencia.php.
    2. Revocar permisos globales del usuario MySQL de la aplicación web y **rotar de emergencia todas las contraseñas de soporte OT y usuarios**, asumiendo que las 32 tablas fueron exfiltradas.
- **Erradicación y Recuperación:**
    1. Refactorizar /validar-referencia.php y el resto de consultas del portal a **PDO con sentencias preparadas** y validación regex estricta del formato LP-INT-XXX-YYYY.
    2. Desactivar display_errors en php.ini y agregar brazo default en el match() de exportar.php.
    3. Migrar todos los hashes de contraseñas en la BD de SHA-1 a **Argon2id**.
- **Criterio de Cierre:** Corrida de validación con sqlmap confirmando que el parámetro ref ya no es inyectable, y confirmación de que todas las credenciales expuestas en las tablas han sido rotadas.

PLAYBOOK 03 (PB-03): Respuesta ante Inyección XSS Almacenado y Lectura Arbitraria de Archivos (Path Traversal)

- **Escenario de INTERAFAS-LAB atendido:** VULN-01, 04 (archivos .zip/.bak expuestos), VULN-08 (Stored XSS en /reportes.php y /seguimiento-reporte.php) y VULN-09 (Path Traversal en /descargar-documento.php?file=../../../../../etc/passwd y /etc/motd).

- **Disparador (*Trigger*):** Detección de etiquetas <script>, fetch() o manejadores de eventos (onload, onerror) en entradas de formularios o en la tabla reportes_ciudadanos; o peticiones hacia /descargar-documento.php que contengan secuencias ../ o %2e%2e%2f.
- **Responsables:** Equipo de Desarrollo Web e Infraestructura Linux (R), Líder CSIRT (A).
- **Evidencia a Recolectar:** Registro en base de datos del reporte malicioso (ej. folio REP-20261011-D9A3AB), logs de peticiones GET a descargar-documento.php mostrando qué archivos del sistema operativo (/etc/passwd, /etc/motd, configuraciones) fueron descargados con código 200 OK.
- **Acciones de Contención:**
    1. Poner en cuarentena/ocultar en base de datos cualquier folio de reporte ciudadano que contenga caracteres < o > e invalidar las sesiones de los operadores que hayan abierto dichos folios.
    2. Bloquear en Apache cualquier URL que contenga .. y retirar del *document root* los archivos .bak y /revision/.
- **Erradicación y Recuperación:**
    1. Limpiar los registros infectados en la tabla reportes_ciudadanos, implementar htmlspecialchars($descripcion, ENT_QUOTES, 'UTF-8') en seguimiento-reporte.php y activar cabecera Content-Security-Policy.
    2. Asegurar descargar-documento.php aplicando basename() y validando con realpath() que el archivo resida dentro de la carpeta de constancias PDF.
    3. Configurar Options -Indexes y <FilesMatch "\.(bak|old|orig|save|swp|zip|env)$"> con Require all denied en Apache.
- **Criterio de Cierre:** Confirmación de que la carga de <script> se renderiza como texto plano inofensivo y que cualquier intento de ../ en descargas devuelve 403/400 sin acceder al sistema de archivos de Debian.

PLAYBOOK 04 (PB-04): Respuesta ante Fraude en Pasarela de Pagos y Abuso de Lógica de Negocio

- **Escenario de INTERAFAS-LAB atendido:** VULN-13 (liquidación de recibo FAC-202609-00001 de $399.24 enviando monto=1.00 en pago.php) y VULN-14 (validación relacional inconsistente entre contract_id=51 y provider_id=107 en validar-vinculo-contractual.php).
- **Disparador (*Trigger*):** Alerta de conciliación financiera donde el importe pagado en pagos_simulados es menor al total/saldo registrado en la tabla facturas (amount-not-revalidated), o consultas/registros de validación contractual donde el provider_id no coincide con el titular adjudicado del contract_id.
- **Responsables:** Equipo de Desarrollo Backend (R), Dirección de Administración, Finanzas y Contrataciones (A), Jurídico (C).
- **Evidencia a Recolectar:** Comprobantes de pago anómalos (ej. referencia PAY-261012-AD7FDE por $1.00 asociada a factura_id=6 y cuenta 40010001), logs de peticiones POST /pago.php y registros de consultas a /validar-vinculo-contractual.php.
- **Acciones de Contención:**
    1. Suspender temporalmente el procesamiento de pagos en /pago.php y congelar la emisión de constancias de no adeudo (constancia_no_adeudo_*.pdf) para cuentas con transacciones bajo revisión.
    2. Deshabilitar temporalmente el validador público /validar-vinculo-contractual.php.
- **Erradicación y Recuperación:**
    1. Modificar el código de /pago.php para eliminar por completo la lectura de $_POST['monto'], obteniendo el importe a cobrar directamente mediante un SELECT saldo FROM facturas WHERE id = :fid en el servidor.

2. Corregir /validar-vinculo-contractual.php mediante una consulta con INNER JOIN que verifique que contratos.proveedor_id = :provider_id.
3. Ejecutar script de conciliación en base de datos para anular las referencias de pago fraudulentas (PAY-261012-AD7FDE) y restaurar el saldo real pendiente ($399.24) en las facturas afectadas.

- **Criterio de Cierre:** Conciliación del 100% de facturas contra pagos recibidos validada por Finanzas, y prueba técnica confirmando que alterar el HTML del formulario de pago no modifica el monto cobrado.

PLAYBOOK 05 (PB-05): Respuesta Crítica ante Intrusión en Red OT, Manipulación de Firmware RTU y Sabotaje de Presión

- **Escenario de INTERAFAS-LAB atendido:** VULN-15 (fuga de red 10.40.20.0/24 en infrastructure-status.php), VULN-16 (bypass de /operations/gateway.php con X-Forwarded-For: 10.40.20.1), VULN-17 (telemetry.php sin sesión), VULN-18 (inyección de firmware 3.4.3 con diagnostic: UNLOCKED sin firma digital en install.php), VULN-19 (mapeo de cadena de dependencias a ZONE-SL-A) y VULN-20 (alteración de pressure_setpoint_bar a 10 bar en RTU-GW-07 causando CATASTROPHIC STATE).
- **Disparador (*Trigger*): PRIORIDAD P1 ABSOLUTA.** Cualquier petición hacia /operations/ con cabecera X-Forwarded-For, acceso a telemetry.php sin sesión activa, cambio del estado de RTU-GW-07 a UNLOCKED / SERVICE, o alerta en el HMI por desviación de pressure_setpoint_bar fuera de 4.1–4.5 bar (PROCESS CASCADE / DANGER).
- **Responsables:** Ingenieros de Operaciones OT en Planta Norte (R - Acción Física), Administradores de Red/Seguridad (R - Aislamiento Lógico), Líder CSIRT y Director de Operaciones OT (A).
- **Evidencia a Recolectar:** Logs de peticiones a /operations/gateway.php, /operations/updates/install.php y /operations/firmware.php; copia del payload JSON malicioso inyectado ("diagnostic":"UNLOCKED", "pressure_setpoint_bar": 10 y hash SHA-256 a0918623...); y volcado de eventos de HIST-01 y ventana MW-260925-01.

- **Acciones de Contención (Ejecución Simultánea en < 10 minutos):**
    1. **Contención Física Hidráulica (En Planta):** Conmutar de inmediato la estación Planta Metropolitana Norte y los 18 PLCs de Cerro de San Pablo, Saint Louis y Soledade a modo **Manual Local**, abriendo válvulas de alivio de sobrepresión y regulando las bombas (p101/p102) físicamente a 4.2 bar para evitar ruptura de tuberías en ZONE-SL-A y el resto de la red.
    2. **Contención Lógica de Red (Corte IT/OT):** Cortar el puente operations-bridge bloqueando en el firewall todo tráfico entre el contenedor web y el segmento 10.40.20.0/24 (OPS-NET-20), y deshabilitando /operations/gateway.php.
    3. **Bloqueo de Mantenimiento:** Cancelar todas las ventanas de mantenimiento activas (MW-260925-01) y revocar las credenciales de Authorization: Basic.
- **Erradicación y Recuperación:**
    1. Suprimir el bloque diagnostics de /api/infrastructure-status.php, eliminar la validación por X-Forwarded-For en el gateway y exigir sesión autenticada con MFA y alcance restringido en telemetry.php y asset-context.php.
    2. Implementar validación obligatoria de **firma criptográfica asimétrica (ECDSA/RSA)** en /operations/updates/install.php y bloqueo de rango (3.5 a 4.8 bar) en /operations/firmware.php.
    3. Flashear en sitio la unidad RTU-GW-07 utilizando la imagen limpia verificada desde el servidor de recuperación BRS-01 (version: 3.4.3, mode: NORMAL, diagnostic: LOCKED, pressure_setpoint_bar: 4.2).
    4. Reconectar estación por estación al HMI verificando que las 6,842 alarmas se limpien a 0 y la disponibilidad operativa regrese al 99.82%.
- **Criterio de Cierre:** Red metropolitana operando de forma estable a 4.2 bar con las 12/12 estaciones en línea, RTU-GW-07 en estado LOCKED, frontera

IT/OT físicamente segregada y prueba de penetración confirmando la imposibilidad de cruzar hacia /operations/ desde el portal web.

10. Post-Incidente, Métricas y Mejora Continua

Reunión de Lecciones Aprendidas y Cierre Formal: Se realiza dentro de los **5 días hábiles** posteriores a la recuperación total, con participación obligatoria de TI, Operaciones OT, Contrataciones, Comunicación y Dirección General, emitiendo el *Informe Final del Incidente INTERAFAS*.

Métricas de Desempeño del CSIRT (KPIs Operativos):

1. **MTTD (*Mean Time to Detect* - Tiempo Medio de Detección):** Meta ≤ 10 minutos desde el primer evento anómalo en logs o telemetría.
2. **MTTC (*Mean Time to Contain* - Tiempo Medio de Contención):** Meta ≤ 15 minutos para incidentes SEV-1 (corte del puente IT/OT y paso a control manual en planta) y ≤ 30 minutos para SEV-2.
3. **MTTR (*Mean Time to Recover* - Tiempo Medio de Recuperación):** Meta ≤ 2 horas para estabilizar al 100% la red hidráulica y ≤ 12 horas para restablecer los servicios web parcheados.

Plan de Acciones Correctivas y Seguimiento hasta la Resolución:

ID Acción	Acción Correctiva Derivada de las Lecciones Aprendidas	Responsable Directo	Plazo de Cierre	Indicador de Verificación
CAPA-01	Desacoplar el servidor web público de la red 10.40.20.0/24 mediante un firewall industrial con DMZ e inspección profunda, eliminando /operations/ del document root público.	Administrador de Redes y Seguridad + Ingeniería OT	**Inmediato (48 hrs)**	Escaneo desde el servidor web hacia 10.40.20.0/24 devuelve 100% paquetes filtrados/bloqueados.
CAPA-02	Integrar análisis estático de código (SAST) y script automático de limpieza post-despliegue en WEBOPS-03 para impedir el paso a producción de código con SQL concatenado, sin htmlspecialchars() o con archivos .bak/.zip.	Líder de Desarrollo WebOps	**7 días**	Pipeline CI/CD rechaza automáticamente despliegues que incumplan el checklist CHK-01 a CHK-20.
CAPA-03	Implementar validación de firma digital por llave pública en RTU-GW-07 y candados físicos de sobrepresión (hardwired safety interlocks) en los 18 PLCs municipales.	Subdirector de Ingeniería y Mantenimiento OT	**14 días**	Prueba de inyección de firmware sin firma y setpoint > 4.8 bar bloqueada en hardware y software.
CAPA-04	Centralizar los logs de Apache, MySQL, HIST-01 y HMI-OPS-01 en un SIEM institucional con alertas automáticas ligadas a los disparadores de los Playbooks PB-01 a PB-05.	Líder del CSIRT / CISO	**30 días**	Reglas de detección activas y probadas mediante simulacro trimestral *Red Team / Blue Team*.